UNIVERSIDAD PRIVADA DE TACNA
FACULTAD DE INGENIERÍA
ESCUELA DE INGENIERÍA DE SISTEMAS

EXAMEN DE LA UNIDAD II · PLAN DE AUDITORÍA

CURSO:

AUDITORIA DE SISTEMAS

URL GITHUB:

https://github.com/srg-cp/si084-caso-clinica/tree/examen-u2

ALUMNO:

2022073503 – Colque Ponce, Sergio

DOCENTE:

DR. OSCAR JUAN JIMENEZ FLORES

TACNA — PERÚ

II. INFORMACIÓN DE LA ENTIDAD AUDITADA Y CONOCIMIENTO PREVIO

La Clínica Santa Lucía S.A.C. es una IPRESS privada de nivel II-1 ubicada en Tacna. La supervisan SUSALUD y la Autoridad Nacional de Protección de Datos Personales. Cuenta con 162 trabajadores, tres de sistemas, e ingresos de S/ 18 600 000 en 2025. Su canal digital ofrece 3 850 citas mensuales, resultados para 12 400 pacientes con cuenta y recepción de 214 postulaciones con CV durante 2026. WebSur S.A.C. desarrolla, aloja y mantiene el portal desde 2021.

Como parte de la planificación, la comisión ejecutó el reconocimiento autorizado del canal digital con la fase de recolección de información de la OWASP Web Security Testing Guide 4.2. El cuadro 1 contrasta lo observado con lo que declara el proveedor.

Cuadro 1. Lo declarado por WebSur S.A.C. frente a lo observado en el reconocimiento

Prueba	Identificador WSTG	Lo observado, con cifras	Declaración	¿Coincide?	Evidencia
E1	WSTG-INFO-04	Responden 3 aplicaciones HTTP 200: portal 8080, pruebas 8081 y API 8088. Pruebas anuncia copia productiva del 12/09/2026. La raíz API anuncia api-citas 1.4.0, entorno produccion y 3 endpoints; no se consultaron.	D1	No	`E1_aplicaciones.txt`
E2	WSTG-INFO-02	Anuncia nginx/1.20.2 y PHP/7.4.3. PHP 7.4 sin soporte desde 28/11/2022 (php.net/eol.php). nginx 1.20 es legado, sustituida por estable 1.22.0 el 24/05/2022 (nginx.org/2022.html); sustitución no acredita EOL contractual.	D2	No	`E2_servidor.txt`
E3	WSTG-INFO-03	Robots enumera 4 rutas: /admin/, /respaldos/, /resultados/ y /wp-content/plugins/wp-file-manager/. security.txt devuelve 404. Robots permite descubrir rutas; no controla acceso.	—	—	`E3_metarchivos.txt`

Prueba	Identificador WSTG	Lo observado, con cifras	Declaración	¿Coincide?	Evidencia
E4	WSTG-INFO-05	4 comentarios; 3 revelan cuenta de pruebas, dirección interna LIS y patrón ver.php?orden=NNNNN. El cuarto identifica proveedor/contacto. Se publica contraseña inicial ddmmaaaa y WordPress 5.8.1. No se probaron identificadores ni la dirección interna.	D8	No	`E4_contenido.txt`
E5	WSTG-INFO-08	4 recursos: medicalpro 2.1.0, Contact Form 7 5.3.1, jQuery 3.4.1 y wp-file-manager ver=6.8. WordPress anuncia 5.8.1 frente a 6.6 declarado. NVD CVE-2020-25213 afecta File Manager anterior a 6.9. Parámetros y banners no prueban instalación ni explotación.	D3	Sin validar	`E5_componentes.txt`
E6	WSTG-INFO-06	4 formularios y 4 actions HTTP. Citas usa GET, solicita identidad/contacto y salud (síntomas/especialidad). Resultados pide DNI/clave; postulaciones, identidad/correo y 1 CV; administración, credenciales. Los tres primeros recogen datos personales. No se enviaron formularios.	D7	Sin validar	`E6_entradas.txt`
E7	WSTG-CONF-04 · CONF-05	Listado de 4 archivos: 2 SQL comprimidos, 1 CSV y 1 copia PHP .bak. /admin/ responde 200 fuera de la red declarada. No se descargaron archivos ni se intentó autenticación.	D5 · D6	No	`E7_expuestos.txt`

Prueba	Identificador WSTG	Lo observado, con cifras	Declaración	¿Coincide?	Evidencia
E8	WSTG-CONF-07 · CONF-12 · SESS-02	Faltan 4 cabeceras: HSTS, CSP, X-Frame-Options y X-Content-Type-Options. Cookie sin Secure, HttpOnly y SameSite: 3 atributos. HTTP responde sin redirección. HTTPS 443 no se consultó por exceder el alcance 8080–8090.	D4	No	`E8_cabeceras.txt`

Las evidencias están en la carpeta evidencias/ del repositorio, selladas en SHA256SUMS.txt. E8 omite consultar 443: el alcance escrito solo autoriza 127.0.0.1:8080–8090; la comisión solicitará aclaración antes de ampliarlo. Las observaciones del 28/10/2026 no acreditan por sí solas la configuración histórica ni la ejecución real de las tecnologías anunciadas.

Ninguna de las ocho declaraciones quedó corroborada íntegramente. D1, D2, D4, D5, D6 y D8 presentan contradicciones observables; D3 muestra versiones incompatibles con el inventario, sin acreditar el historial mensual; D7 queda sin sustento ante GET, sin probar filtración efectiva. La comisión adoptará un enfoque sustantivo. El patrón de orden y la contraseña predecible de E4 justifican investigar acceso indebido en relación con el incidente del 08/09/2026. La hipótesis de caché también se evaluará; ninguna causa quedó demostrada mediante este reconocimiento.

III. DENOMINACIÓN DE LA MATERIA DE CONTROL

La comisión auditará la protección de los datos personales y de salud tratados por el canal digital de la Clínica Santa Lucía entre el 01/01/2026 y el 30/09/2026. La materia comprenderá acceso, sesiones, transmisión, formularios, configuración y custodia vinculados con esos datos. Se justifica por el resultado ajeno observado el 08/09/2026 y por E4, E6 y E8, que muestran identificadores de resultados, transmisión prevista mediante GET y ausencia de protecciones de sesión. La prioridad será la confidencialidad de la información clínica.

IV. ALCANCE

IV.1 Incluye. La comisión incluirá el portal http://127.0.0.1:8080/, con 3 850 citas mensuales, resultados para 12 400 pacientes y 214 postulaciones con CV durante 2026, además de administración y exposición de respaldos. Incluirá pruebas en http://127.0.0.1:8081/, que anuncia una copia productiva del 12/09, cuya población y anonimización se determinarán. Incluirá la API http://127.0.0.1:8088/, que anuncia citas, pacientes y resultados vinculados con las poblaciones del portal, sin asumir su replicación íntegra. Revisará inventario, configuración, accesos y obligaciones de WebSur relacionados con estos activos.

IV.2 Periodo auditado. La comisión revisará del 01/01/2026 al 30/09/2026, conforme a la solicitud, porque comprende el incidente y la copia anunciada en septiembre. Contrastará el reconocimiento del 28/10 con registros históricos. Solicitará el corte de postulaciones al 30/09: las 214 declaradas corresponden a 2026 completo.

IV.3 Exclusiones. La comisión excluirá auditoría financiera y asistencial, dispositivos médicos, infraestructura física, red interna y LIS porque no pertenecen al canal digital autorizado. No enviará tráfico a dominios .test, 10.20.0.15 ni producción real. En Unidad II excluirá formularios enviados, autenticación, descarga de respaldos, /v1/, fuzzing y escaneo activo por falta de autorización. Su prueba posterior requerirá aprobación escrita. No examinará operaciones de 2025; sí considerará la exposición actual del respaldo cuyo nombre corresponde a ese año.

IV.4 Limitaciones inherentes. La auditoría proporcionará seguridad razonable, no absoluta. La réplica estática no permitirá acreditar autenticación o acceso efectivo a bases de datos; la Unidad III requerirá réplica funcional y datos sintéticos. La comisión no concluirá eficacia histórica sin logs o cambios del periodo. Determinará la población real de copias y API. Las muestras dirigidas no permitirán extrapolación estadística. Registrará las restricciones y servicios no disponibles como limitaciones, sin sustituirlos por conclusiones favorables; HTTPS 443 quedará pendiente de aclaración.

V. OBJETIVOS

Objetivo general. Determinar si los controles del canal digital protegieron la confidencialidad, integridad y disponibilidad de los datos durante el periodo auditado, utilizando OWASP WSTG 4.2, OWASP ASVS 4.0.3, NTP-ISO/IEC 27001:2022 y Ley 29733 como criterios de evaluación.

Objetivo específico 1. Evaluar autenticación, autorización y separación de sesiones/caché conforme a WSTG-ATHZ-04, WSTG-ATHN-07 y ASVS V4.2.1 y V8.1.1, para determinar si explican o permiten repetir el incidente.

Pregunta de auditoría: ¿Una cuenta puede consultar resultados de otro titular o recuperar de caché información ajena?

Objetivo específico 2. Verificar configuración, inventario, actualización, segregación y protección de administración/respaldos conforme a WSTG-CONF-04 y CONF-05, ASVS V14.2.1 y NTP A.8.8 y A.8.31.

Pregunta de auditoría: ¿Los tres activos y componentes se mantienen inventariados y protegidos frente a acceso no autorizado?

Objetivo específico 3. Determinar la protección de transmisión, cookies y recopilación conforme a WSTG-CRYP-03, WSTG-SESS-02, ASVS V8.3.1 y V8.3.3 y Ley 29733 arts. 9, 13 y 18.

Pregunta de auditoría: ¿Los flujos evitan datos sensibles en claro o URL y acreditan información previa y base habilitante del tratamiento?

VI. ENFOQUE, MATERIALIDAD Y RIESGO DE AUDITORÍA

VI.1 Enfoque. La comisión adoptará un enfoque sustantivo mediante inspección documental y pruebas directas autorizadas. E1 y E7 contradicen el inventario y las restricciones declaradas; E8 muestra cabeceras y atributos ausentes. No depositará confianza en las afirmaciones del proveedor ni probará eficacia operativa de controles inexistentes; determinará el diseño y funcionamiento real de los controles implementados durante la ejecución posterior.

VI.2 Materialidad. La comisión propondrá un umbral cuantitativo de planificación del 1 % de las 12 400 cuentas declaradas, equivalente a 124 cuentas potencialmente afectadas, para priorizar extensión y escalamiento. Considerará por separado 3 850 citas mensuales y 214 postulaciones de 2026, sin equiparar citas con personas únicas ni inventar pérdidas monetarias. Cualitativamente, una sola revelación no autorizada de salud será material, cualquiera sea su importe o número de afectados, por el carácter sensible del dato y los deberes de seguridad y confidencialidad de la Ley 29733, artículos 2.5, 9 y 17. Esta condición prevalecerá sobre el umbral cuantitativo.

VI.3 Riesgo de auditoría. La comisión calificará el riesgo inherente como alto por la naturaleza sanitaria, las 12 400 cuentas y el incidente comunicado; E6 confirma recopilación de síntomas. Evaluará preliminarmente como alto el riesgo de control por el listado y la interfaz expuestos de E7 y las protecciones ausentes de E8. Considerará alto el riesgo de detección si solo dispone de reconocimiento y réplica estática, sin logs históricos; fijará un nivel aceptable objetivo bajo y procurará reducirlo con consultas cruzadas sintéticas, evidencia histórica, cobertura de los tres activos y revisión de resultados. No dará por acreditada esa reducción antes de ejecutar los procedimientos.

VII. PROCEDIMIENTOS DE AUDITORÍA

La comisión ejecutará seis procedimientos en la Unidad III sobre la réplica funcional autorizada, una vez aprobado el plan. Cubrirá OE1–OE3 y seis categorías WSTG 4.2: ATHZ, ATHN, SESS, CRYP, CONF y BUSL. Acordará por escrito activos, cuentas, operaciones y puertos, utilizará datos sintéticos y registrará cualquier falta de autorización o funcionalidad como limitación. Estimará 22 horas de trabajo. No ejecutó estas pruebas durante el reconocimiento.

P-01 · Autorización y caché de resultados

Elemento	Contenido
Objetivo específico	OE1. Respuesta directa al incidente del 08/09/2026.
Origen en el reconocimiento	E4: patrón ver.php?orden=NNNNN; E1: API anuncia resultados. Incidente e hipótesis de caché: solicitud.
Riesgo que cubre	Consulta de resultados de otro paciente por autorización insuficiente o caché compartida.
Criterio	WSTG-ATHZ-04 · WSTG-ATHN-06 · ASVS 4.0.3 V4.2.1, V8.1.1, V8.2.1 · NTP-ISO/IEC 27001:2022 A.8.3 · Ley 29733 arts. 9 y 17.
Tipo de prueba	Sustantiva de autorización/aislamiento de caché e inspección del incidente.
Población y muestra	Marco: 12 400 cuentas; cantidad de resultados por confirmar. Muestra dirigida: 2 cuentas ficticias A/B, 2 órdenes por cuenta, en portal y API si se habilita. Censo del expediente y logs conservados del incidente, mediante datos disociados.
Evidencia a obtener	Matriz cuenta-orden-canal, respuestas, cabeceras y marcadores sintéticos; trazabilidad del expediente sin datos clínicos.
Definición de excepción	Una respuesta entrega un resultado de otro titular ficticio, o contenido de A aparece en sesión/caché de B o sin sesión. Falta de expediente: limitación documental, no causa técnica demostrada.
Horas estimadas	5 horas.

Pasos.

1. Obtenga autorización escrita para consultas autenticadas y endpoints concretos; confirme aislamiento de producción.
2. Prepare dos cuentas y cuatro resultados sintéticos con titularidad esperada; limite los identificadores a esas cuatro órdenes.
3. Consulte cada orden con su propietario, con la otra cuenta y sin sesión. Registre si la aplicación devuelve contenido ajeno o deniega acceso.
4. Repita en navegadores separados, tras cerrar sesión y con caché habilitada; capture Cache-Control, Vary y marcador visible. Repita en API solo si está habilitada y autorizada.
5. Solicite expediente, análisis causal y logs del incidente; correlacione titularidad, accesos y cambios de caché usando identificadores disociados.
6. Compare con la excepción y declare si se acreditó la causa o sigue indeterminada.

P-02 · Credenciales iniciales y recuperación

Elemento	Contenido
Objetivo específico	OE1.
Origen en el reconocimiento	E4: contraseña por fecha de nacimiento y cuenta de pruebas anunciada; E6: formularios de acceso.
Riesgo que cubre	Suplantación por secretos predecibles o recuperación sin acreditar identidad.
Criterio	WSTG-ATHN-07 · WSTG-ATHN-09 · ASVS 4.0.3 V2.1.1 y V2.5.2 · NTP-ISO/IEC 27001:2022 A.8.5 · Ley 29733 arts. 9 y 17.
Tipo de prueba	Sustantiva funcional e inspección del proceso de alta/recuperación.
Población y muestra	Procesos de pacientes y administración. Dos pacientes ficticios recién registrados y una cuenta administrativa de prueba proporcionada por Sistemas. No se harán intentos masivos sobre las 12 400 cuentas.
Evidencia a obtener	Política y capturas de alta, cambio obligatorio y recuperación; registro de intentos autorizados con secretos ocultos.
Definición de excepción	Una cuenta admite nacimiento como secreto de ocho caracteres, permite acceso sin sustituir la credencial inicial o recupera acceso sin el mecanismo aprobado de acreditación de identidad.
Horas estimadas	3 horas.

Pasos.

1. Solicite política y procesos del periodo; acuerde máximo de un intento por credencial ficticia conocida, sin fuerza bruta.
2. Observe dos altas ficticias y la credencial entregada; compruebe longitud mínima de 12 caracteres de ASVS V2.1.1 y ausencia de fechas públicas como secreto.
3. Compruebe cambio obligatorio antes de ver resultados; no use la cuenta admin_pruebas descubierta ni otras identidades reales.
4. Ejecute recuperación ficticia y compruebe acreditación de identidad. Simule cualquier atención por WhatsApp con la contraparte, sin enviar mensajes a terceros.
5. Revise el acceso administrativo con credenciales suministradas; documente excepciones y restaure las cuentas de prueba.

P-03 · Transporte y cookies de sesión

Elemento	Contenido
Objetivo específico	OE3.
Origen en el reconocimiento	E8: HTTP, cuatro cabeceras y tres atributos ausentes; E6: cuatro actions HTTP.
Riesgo que cubre	Intercepción de datos y uso indebido de sesiones.
Criterio	WSTG-CRYP-03 · WSTG-SESS-02 · ASVS 4.0.3 V9.1.1, V3.4.1, V3.4.2 y V3.4.3 · NTP-ISO/IEC 27001:2022 A.8.24 · Ley 29733 art. 9.
Tipo de prueba	Sustantiva de configuración y transmisión sintética.
Población y muestra	Censo de 3 activos y 4 formularios; cookies de los flujos autorizados de 2 cuentas ficticias. Puertos TLS definidos en nueva autorización.
Evidencia a obtener	Matriz de transporte, redirecciones, cabeceras y cookies; solicitudes con tokens ocultos.
Definición de excepción	Un flujo sensible usa HTTP; una cookie carece de Secure, HttpOnly o SameSite; o falta una de las cuatro cabeceras sin un control equivalente evaluado y documentado.
Horas estimadas	3 horas.

Pasos.

1. Resuelva por escrito el alcance de puertos TLS, incluido 443; no presuma autorización previa.
2. Compruebe redirecciones antes de enviar datos y destinos TLS en los cuatro formularios de la réplica funcional.
3. Complete los flujos permitidos con marcadores ficticios y examine solicitudes en el navegador; oculte tokens al guardar evidencia.
4. Inspeccione los tres atributos de cookies y cuatro cabeceras; evalúe HSTS sobre HTTPS, no solo sobre HTTP.
5. Registre por separado excepciones comprobadas, servicios no disponibles y restricciones de alcance.

P-04 · Administración y respaldos

Elemento	Contenido
Objetivo específico	OE2.
Origen en el reconocimiento	E3 revela rutas; E7 lista cuatro archivos y /admin/ HTTP 200.
Riesgo que cubre	Acceso no autorizado a copias, configuración o funciones privilegiadas.
Criterio	WSTG-CONF-04 · WSTG-CONF-05 · ASVS 4.0.3 V4.3.1, V4.3.2 y V8.1.6 · NTP-ISO/IEC 27001:2022 A.8.3 y A.8.13 · Ley 29733 arts. 9 y 17.
Tipo de prueba	Inspección y prueba sustantiva de restricciones.
Población y muestra	Censo de /admin/, /respaldos/ y los cuatro nombres listados. Una copia señuelo sintética por tipo (.sql.gz, .csv y .bak); no se usarán archivos originales.
Evidencia a obtener	Reglas de acceso, matriz de roles/redes, respuestas a señuelos y contrato/política de custodia.
Definición de excepción	Un usuario no autorizado obtiene un señuelo, listado sensible o función privilegiada; o la interfaz declarada interna es accesible desde la red externa de prueba. Login visible no demuestra privilegios.
Horas estimadas	3 horas.

Pasos.

1. Obtenga permiso de pruebas y cree señuelos sintéticos con Sistemas.
2. Inspeccione raíz web, autoindex, permisos, almacenamiento y responsabilidades contractuales de respaldo/restauración.
3. Compare acceso anónimo y autorizado desde perfiles de red aprobados, sin probar contraseñas desconocidas.
4. Verifique copias fuera de raíz pública, acceso restringido y mecanismo de restauración documentado.
5. Registre excepciones y retire señuelos. No descargue los cuatro archivos originales del reconocimiento.

P-05 · Componentes entornos y proveedor

Elemento	Contenido
Objetivo específico	OE2.
Origen en el reconocimiento	E1: pruebas con copia y API no inventariadas; E2/E5: versiones antiguas; E4: datos internos.
Riesgo que cubre	Componentes sin mantenimiento y copias productivas en entornos insuficientemente protegidos.
Criterio	WSTG-CONF-02 · ASVS 4.0.3 V14.2.1 y V14.2.5 · NTP-ISO/IEC 27001:2022 A.8.8, A.8.31, A.8.33 y A.5.20 · Ley 29733 art. 9.
Tipo de prueba	Inspección sustantiva de inventario, configuración e historial.
Población y muestra	Censo de 3 activos y 7 tecnologías anunciadas: nginx, PHP, WordPress, medicalpro, Contact Form 7, jQuery y wp-file-manager. Nueve registros mensuales enero-septiembre y expediente de copia del 12/09.
Evidencia a obtener	Inventario/SBOM validado, versiones reales, tickets, análisis CVE, segregación, autorización de copia y contrato.
Definición de excepción	Activo sin responsable/inventario; componente real sin soporte o con CVE aplicable sin tratamiento aprobado; copia productiva en pruebas sin autorización y protección equivalente o anonimización acreditada.
Horas estimadas	4 horas.

Pasos.

1. Solicite inventario, SBOM, configuración y contrato; contraste los tres activos y sus responsables.
2. Confirme las siete tecnologías mediante inventario autenticado; diferencie banners simulados de software instalado.
3. Contraste versiones reales con fuentes oficiales y CVE-2020-25213; determine condiciones de aplicabilidad sin exploits.
4. Revise los nueve registros mensuales para evaluar D3; no infiera periodicidad de una versión en URL.
5. Inspeccione separación y expediente de copia del 12/09: autorización, anonimización, protección y eliminación, mediante metadatos/informes sin copiar datos personales.
6. Identifique comentarios internos y responsables de retiro; documente excepciones por activo y periodo acreditado.

P-06 · Formularios consentimiento y archivos

Elemento	Contenido
Objetivo específico	OE3.
Origen en el reconocimiento	E6: GET con síntomas, casilla acepto y CV. La solicitud declara que la casilla carece de texto.
Riesgo que cubre	Datos en URL, tratamiento sin garantías y recepción insegura de archivos.
Criterio	WSTG-BUSL-01 · WSTG-BUSL-08 · ASVS 4.0.3 V8.3.1, V8.3.3 y V12.1.1 · NTP-ISO/IEC 27001:2022 A.5.34 y A.8.26 · Ley 29733 arts. 13.5, 13.6, 14 y 18.
Tipo de prueba	Sustantiva funcional e inspección documental del tratamiento.
Población y muestra	Censo de 4 formularios. Dos citas ficticias (aceptación/no aceptación), una consulta ficticia de resultados y tres postulaciones con archivos inertes (PDF permitido, tipo no permitido y PDF sobre límite acordado). Marco declarado: 3 850 citas/mes, 12 400 cuentas y 214 postulaciones en 2026. Muestra dirigida sin extrapolación.
Evidencia a obtener	Matriz campos-finalidad-base habilitante, aviso, registro de consentimiento cuando proceda y decisiones de validación de CV.
Definición de excepción	DNI, síntomas, contraseña o token en URL; recopilación sin información del art. 18; falta de consentimiento exigible sin excepción legal acreditada; aceptación de archivo contrario a tipo/tamaño previamente aprobados.
Horas estimadas	4 horas.

Pasos.

1. Obtenga autorización de envíos en réplica funcional y política previa de tipos/tamaño. Use identidades ficticias y archivos inertes, sin código activo.
2. Relacione campos con finalidad, obligatoriedad, conservación y destinatarios; solicite aviso y base habilitante por tratamiento.
3. Revise información previa del art. 18 y consentimiento cuando proceda según arts. 13.5/13.6; evalúe excepciones pertinentes del art. 14. No presuma que consentimiento sea la única base para toda atención sanitaria.
4. Ejecute citas y consulta ficticias; revise URL, historial y registros sin conservar valores personales.
5. Envíe los tres CV inertes autorizados; compare decisiones con la política fijada antes de probar y revise permisos/ubicación del aceptado.
6. Documente excepciones por formulario y elimine datos ficticios dejando constancia.

ANEXO A. MATRIZ DE RIESGOS DE LA MATERIA DE CONTROL

N.º	Riesgo	Causa, con su evidencia	Impacto	Nivel	Control existente	Control esperado
R1	Datos ajenos.	E4: clave por fecha y orden en URL. Incidente según solicitud; causa sin probar.	Fuga de datos de salud.	Alto	E6: DNI y clave; eficacia sin probar.	Acceso por titular; caché por cuenta y clave segura. P-01/P-02.
R2	Copias y panel sin filtro.	E7: 4 archivos listados y /admin/ visible. E3 revela rutas.	Fuga masiva o uso indebido del panel.	Alto	Login visible; filtro de red no visto.	Copias fuera de la web; sin listado; filtro de red y MFA. P-04.
R3	Robo de datos o sesión.	E8: faltan 4 cabeceras y 3 atributos de cookie. E6: HTTP.	Fuga de datos y uso de cuenta ajena.	Alto	Cookie con path=/; HTTP sin redirigir. TLS sin probar.	TLS; cookies con Secure, HttpOnly y SameSite. P-03.
R4	Software viejo y pruebas con copia.	E1: copia anunciada y 3 activos. E2/E5: versiones antiguas.	Fuga o cambio de datos; caída del portal.	Alto	Etiqueta de pruebas; copia sin validar.	Registro de activos; parches; entornos separados y datos seguros. P-05.
R5	Datos y CV sin garantías.	E6: GET con síntomas y campo CV. Casilla sin texto según solicitud.	Datos en URL y riesgo para derechos.	Alto	Casilla de acepto; aviso y filtro de CV sin probar.	Datos fuera de URL; aviso y base legal; filtro de CV. P-06.

Elaborado por: Sergio Colque Ponce · Código: 2022073503 · Fecha: 28/10/2026